

NIST SP 800-53 Rev 5: Security and Privacy Controls for Information Systems

Page 1 of 3 | Document ID: doc_en_01

Chapter 1: Scope, Applicability, and Control Framework Architecture

NIST SP 800-53 provides a catalog of security and privacy controls for federal and institutional information systems.

The controls are organized into twenty families covering management, operational, technical, and privacy protection domains.

Section AC-2: Account Management Requirements and Inactive Identity Handling

Organizations must systematically manage information system accounts including creation, modification, and disabling.

The organization requires automatically disabling inactive system accounts after a maximum inactivity period of 90 days.

Temporary and guest accounts must be configured to expire automatically after a predefined period not exceeding 30 days.

NIST SP 800-53 Rev 5: Security and Privacy Controls for Information Systems

Page 2 of 3 | Document ID: doc_en_01

Section AU-6: Audit Review, Analysis, and Automated Reporting Procedures

Organizations must review and analyze information system audit records systematically for indications of unusual activity.

The organization must integrate automated mechanisms to alert security personnel of suspicious activities and threshold anomalies.

Audit logs must be synchronized using Network Time Protocol (NTP) to a trusted external time source within 100 milliseconds.

Section IA-5: Authenticator Management and Password Complexity Guidelines

System authenticators must enforce minimum complexity requirements including at least 15 characters for privileged accounts.

Multi-factor authentication (MFA) must be enforced for all local and network access to privileged administrative interfaces.

NIST SP 800-53 Rev 5: Security and Privacy Controls for Information Systems

Page 3 of 3 | Document ID: doc_en_01

Section SC-8: Transmission Confidentiality and Integrity Protection

Information systems must protect the confidentiality and integrity of transmitted data across external and internal networks.

All cryptographic modules used for data in transit and at rest must be validated under FIPS 140-2 or FIPS 140-3 standards.

Legacy encryption algorithms such as DES, 3DES, and RC4 are explicitly prohibited across federal production systems.

Section CP-9: System Backup Redundancy and Off-Site Storage

System-level backups must be conducted daily for transactional data and weekly for complete system operating images.

Backup media must be stored at a geographically distinct off-site location protected by equivalent physical security controls.